

The Gizmoduck Plugin: Technical Reference

Generated from useful-claude-add-ons@541b2b70 on 2026-09-22. Verify before trusting.

The low-level guide, for the people who install, run and extend gizmoduck. A companion overview covers the same ground in plain language. Written against gizmoduck 0.5.3, commit 541b2b70.

Scope. Gizmoduck runs [Nuclei](#) (MIT-licensed, self-hosted) end to end — scan, normalise,

report, ticket, diff — with no export step and no third-party API in the loop. Runs on

WSL/Linux and Windows.

1. Layout

Path	Contents
<code>.claude-plugin/plugin.json</code>	Name, version (0.5.3), description, licence (GPL-2.0-only).
<code>bootstrap.sh / bootstrap.ps1</code>	Installers for Linux/WSL and Windows: fetch Nuclei and community templates, and install wkhtmltopdf plus the nine multi-tool-routine scanners (nmap, nikto, testssl, trivy, checkov, semgrep, dependency-check, sqlmap, zap).
<code>scripts/gizmoduck.py</code>	The CLI: scan, summary, parse, report, tickets, diff, doctor, update.
<code>scripts/normalize.py</code>	Finding shape and severity normalisation shared by every scanner adapter; imports nothing from <code>gizmoduck.py</code> so adapters and their tests load without the CLI.
<code>scripts/report_template.py</code>	HTML and PDF rendering, via wkhtmltopdf (Qt WebKit 4.8 — no flexbox, grid or custom properties in its CSS).
<code>scripts/routine.py</code>	Manifest-driven, multi-tool scan orchestrator over the nine

Path	Contents
	adapters in scripts/scanners/, with an authorisation gate. Not wired to any command in this repository as of this commit — nothing outside scripts/_test/ imports it.
scripts/scanners/	One adapter module per tool: nuclei, nmap, nikto, testssl, trivy, checkov, semgrep, depcheck, sqlmap, zap, plus base.py for the shared contract.
commands/	Six command files: scan, report, tickets, diff, update, doctor.
skills/gizmoduck/ SKILL.md	The workflow the agent follows: scan, summarise, report, ticket.
docs/antivirus- exclusions.md	What to exclude so an AV/EDR does not quarantine nikto, sqlmap, ZAP or a Nuclei template mid-install.
scripts/_test/	23 test modules.

2. The CLI

Subcommand	Positional args	Severity floor	Notes
scan	target/host/ URL/file	n/a	--severity passed straight through as Nuclei's own filter; --extra passes through additional Nuclei args; writes JSONL to --out (default findings.jsonl).
summary	findings.jsonl	info (everything)	Prints the severity counts as JSON.
parse	findings.jsonl	info	Prints the raw findings at or above --min-severity as JSON.
report	findings.jsonl	medium	Itemises Critical/High/Medium; Low/Info are counted and dropped, with the suppressed

Subcommand	Positional args	Severity floor	Notes
			count stated. <code>--format md html pdf</code> ; PDF falls back to HTML with a message and exit 2 if no PDF engine is found.
tickets	findings.jsonl	high	Gated: without <code>--yes <digest></code> , prints the candidate list and a digest, then exits 3 with no ticket records emitted. A wrong or stale digest exits 3 as <code>GIZMODUCK_APPROVAL_MISMATCH</code> . Zero qualifying findings prints <code>[]</code> and exits 0 either way.
diff	baseline.jsonl, current.jsonl	low	What is new in current relative to baseline.
doctor	none	n/a	Checks <code>nuclei</code> , its templates directory, Python, <code>wkhtmltopdf</code> , <code>NVD_API_KEY</code> (presence only, never the value), and every registered scanner adapter's <code>is_available()</code> . Exits 1 only if <code>nuclei</code> or its templates are missing; a missing supporting tool or an unset <code>NVD_API_KEY</code> is reported but never flips the exit code.
update	none	n/a	Updates the Nuclei engine and community templates.

`argparse` runs with `allow_abbrev=False`, so `--yes` must be spelled out in full — an abbreviation cannot trip the ticketing gate by accident. `--yes` is refused with a named error on every subcommand except `tickets`, rather than being silently ignored.

3. The Ticketing Gate

`cmd_tickets` computes a digest over the exact record set (`_records_digest`) and requires it back, verbatim, on `--yes`:

- No `--yes`: prints one line per candidate ticket (severity + subject), the digest, and the

exact rerun command carrying it; exits 3 with `GIZMODUCK_CONFIRMATION_REQUIRED` and no JSON.

- `--yes` present but not equal to the freshly recomputed digest: exits 3 with `GIZMODUCK_APPROVAL_MISMATCH` — a different findings file, a different `--min-severity`, or findings that changed in between all produce this.
- `--yes` matching: emits the JSON ticket records for the caller (the `/gizmoduck:scan` and `/gizmoduck:tickets` command prose) to act on.

The severity floor for tickets defaults to High rather than the CLI-wide Info default, specifically so a bare invocation cannot open a ticket per informational finding.

4. Severity Model

`SEV_NUM` (`gizmoduck.py:38`, mirrored in `normalize.py` with a parity note): `critical=4`, `high=3`, `medium=2`, `low=1`, `info=0`, `unknown=0`. `normalize.py` maps a handful of legacy tool vocabularies onto this scale (Bridgecrew's "moderate"/"important", ZAP's numeric riskcode 0-3) and reports anything it cannot map as unknown rather than guessing a severity for it.

5. The Routine Orchestrator (Not yet a Command)

`scripts/routine.py` implements a manifest-driven, multi-tool scan (`run_routine`), each of the nine adapters conforming to one contract: `run(location, outdir, opts) -> (raw_path | None, ToolResult)` and `parse(raw_path, name) -> list[dict]`, called with plain strings rather than a `Target` object. `result.returncode is None` means an adapter declined to run an active scan before firing anything (currently only `sqlmap`'s active mode) — reported as `skipped-active`, never as an error. `doctor` already surfaces every adapter's availability under `-- scanners --`, driven off the same registry, so a tool added to `scanners/` can never go unmentioned there — but as of this commit nothing in `commands/` or `skills/gizmoduck/SKILL.md` calls `run_routine`; the only exercised path into it is `scripts/_test/`.

6. Bootstrap and Dependencies

Dependency	Installed by bootstrap	If missing
Nuclei + community templates	Yes	scan reports it and stops.
wkhtmltopdf	Yes (Linux via apt; Windows via winget install wkhtmltopdf)	report --format pdf falls back to writing HTML and exits 2 with a message.
nmap, nikto, testssl, trivy, checkov, semgrep, dependency-check, sqlmap, zap	Yes, for the routine orchestrator	A degraded routine run per doctor's per-adapter report; none of this affects the scan/report/tickets path, which only needs Nuclei.
NVD_API_KEY (environment variable)	Not installed — optional, user-supplied	dependency-check's first NVD sync rate-limits to about 5 requests/30s instead of about 50/30s; doctor reports the variable's presence only, never its value.

7. Known Items

- The nine-tool `routine.py` orchestrator has no slash command or skill entry point in this repository yet, despite doctor already reporting on all nine adapters' availability.
- `docs/antivirus-exclusions.md` documents that an AV/EDR quarantining or deleting nikto, sqlmap, ZAP or a Nuclei template mid-install is an expected interaction with this toolchain, not a broken install — worth checking before assuming doctor's report of a missing tool means the bootstrap script failed.

Provenance: read from `plugin/gizmoduck/README.md`, `scripts/gizmoduck.py`, `scripts/normalize.py`, `scripts/routine.py`, `scripts/report_template.py`, `bootstrap.sh` and `scripts/_test/` at commit 541b2b70 (gizmoduck 0.5.3, confirmed in both `.claude-plugin/plugin.json` and `CHANGELOG.md`). Not verified: a live scan or ticketing run against a real ServiceDesk Plus instance.